VULNERABILITY ASSESSMENT REPORT

Target: http://demo.testfire.net

Prepared by: Khuthadzo Makuya

Date: 06 April 2026

Introduction

This report presents the results of a vulnerability assessment conducted on the web application http://demo.testfire.net. The purpose of this assessment was to identify security weaknesses that could be exploited by attackers and to recommend solutions to improve system security.

The assessment focused on both network-level and web application vulnerabilities using industry-standard tools.

Tools Used

- Nmap (Network scanning)
- OWASP ZAP (Web vulnerability scanning)
- Browser Developer Tools

Methodology

The assessment was conducted in two phases:

Phase 1: Network Scanning

A scan was performed using Nmap to detect open ports and services on the target system. The -Pn option was used to bypass host detection restrictions.

Phase 2: Web Application Scanning

An automated scan was performed using OWASP ZAP to identify common web vulnerabilities such as SQL Injection and Cross-Site Scripting.

Findings

1. **Network Scan Results**

The Nmap scan showed that all 1000 scanned ports were filtered. This indicates that the target system is protected by a firewall or intrusion detection system.

Risk Level: Low

2. **Cross-Site Scripting (XSS)**

Risk Level: High

Description: The application allows execution of malicious scripts in the user's browser.

Impact: Attackers can steal user data or hijack sessions.

Solution: Validate user input and encode output.

3. **SQL Injection**

Risk Level: High

Description: The application is vulnerable to database manipulation through user input.

Impact: Attackers can access or modify sensitive data.

Solution: Use parameterized queries and input validation.

4. **Missing Anti-CSRF Tokens**

Risk Level: Medium

Description: The application does not protect against unauthorized requests.

Impact: Attackers can perform actions on behalf of users.

Solution: Implement CSRF tokens.

5. **Missing Security Headers**

Risk level: Medium

Description: Important browser security protections are not enabled.

Impact: Increased risk of attacks like clickjacking.

Solution: Add headers like Content-Security-Policy and X-Frame-Options.

Risk Analysis

The assessment identified critical vulnerabilities such as XSS and SQL Injection, which pose a high risk to the system. These vulnerabilities could allow attackers to compromise user data and system integrity.

Although network-level protection is present, the web application remains vulnerable.

Recommendations

- Validate and sanitize all user inputs
- Use secure coding practices
- Implement CSRF protection
- Configure HTTP security headers
- Secure cookies properly
- Minimize information exposure

Conclusion

The vulnerability assessment revealed several security weaknesses in the web application. Immediate action is required to address high-risk vulnerabilities.

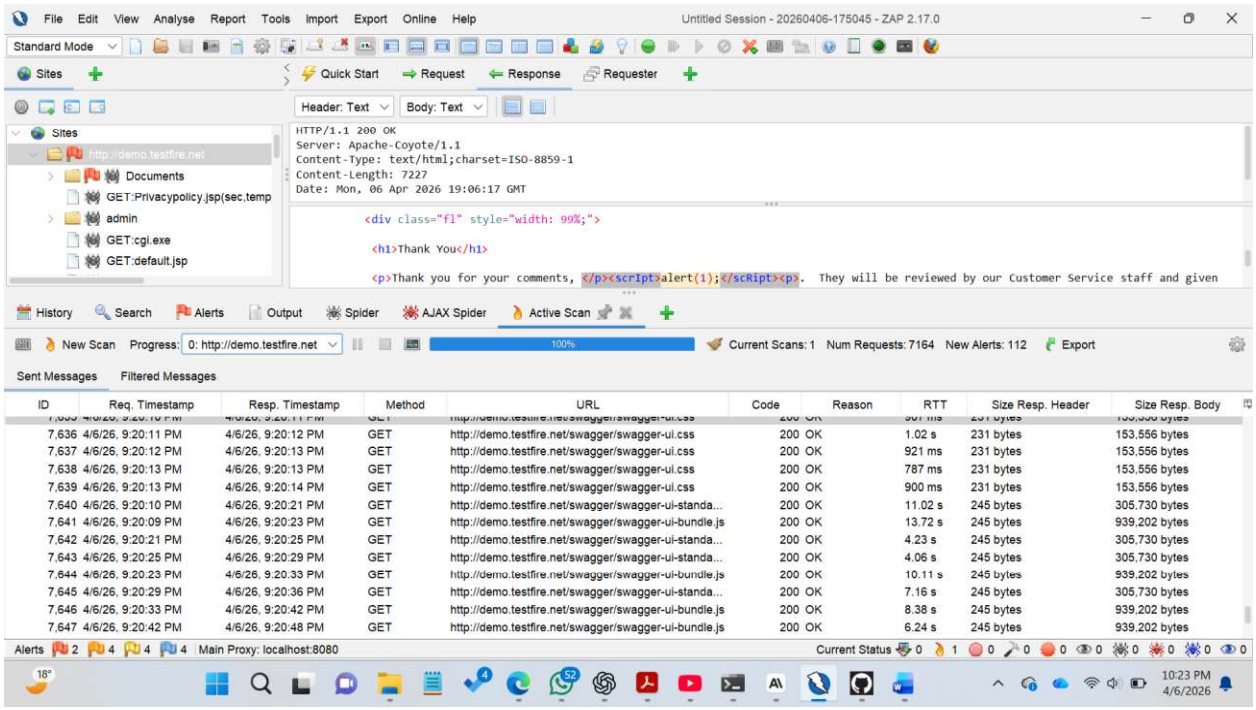
Implementing the recommended measures will significantly improve the security of the system.

Screenshots

```
C:\Users\Khuthadzo Mak>nmap -sV -Pn demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-06 22:25 +0200
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.80% done; ETC: 22:27 (0:01:41 remaining)
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 9.00% done; ETC: 22:26 (0:01:01 remaining)
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 13.80% done; ETC: 22:26 (0:00:44 remaining)
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.29s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE   VERSION
80/tcp   open   http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open   ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open   http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.32 seconds

C:\Users\Khuthadzo Mak>
```



File Edit View Analyse Report Tools Import Export Online Help — Untitled Session - 20260406-175045 - ZAP 2.17.0

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 7227
Date: Mon, 06 Apr 2026 19:06:17 GMT
```

```
<div class="fl" style="width: 99%;">

 <h1>Thank You</h1>

 <p>Thank you for your comments, </p><scrIpt>alert(1);</scRipt><p>.  They will be reviewed by our Customer Service staff and given
```

Sites
- http://demo.testfire.net
  - Documents
    - GET:Privacypolicy.jsp(sec,temp
  - admin
    - GET:cgi.exe
    - GET:default.jsp

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

New Scan | Progress: 0: http://demo.testfire.net | 100% | Current Scans: 0 | URLs Found: 234 | Nodes Added: 83 | Export

URLs | Added Nodes | Messages

Processed	Method	URI	Flags
	GET	http://demo.testfire.net	Seed
	GET	http://demo.testfire.net/robots.txt	Seed
	GET	http://demo.testfire.net/sitemap.xml	Seed
	GET	http://demo.testfire.net/index.jsp	
	GET	http://demo.testfire.net/login.jsp	
	GET	http://demo.testfire.net/index.jsp?content=inside_contact.htm	
	GET	http://demo.testfire.net/feedback.jsp	
	GET	http://demo.testfire.net/index.jsp?content=personal.htm	
	GET	http://demo.testfire.net/index.jsp?content=business.htm	
	GET	http://demo.testfire.net/index.jsp?content=inside.htm	
	GET	http://demo.testfire.net/index.jsp?content=personal_deposit.htm	
	GET	http://demo.testfire.net/index.jsp?content=personal_checking.htm	

Alerts 2 4 4 4 | Main Proxy: localhost:8080 | Current Status 0 1 0 0 0 0 0 0 0 0 0

10:24 PM 4/6/2026

File Edit View Analyse Report Tools Import Export Online Help — Untitled Session - 20260406-175045 - ZAP 2.17.0

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=ISO-8859-1
Content-Length: 7227
Date: Mon, 06 Apr 2026 19:06:17 GMT
```

```
<div class="fl" style="width: 99%;">

 <h1>Thank You</h1>

 <p>Thank you for your comments, </p><scrIpt>alert(1);</scRipt><p>.  They will be reviewed by our Customer Service staff and given
```

Sites
- http://demo.testfire.net
  - Documents
    - GET:Privacypolicy.jsp(sec,temp
  - admin
    - GET:cgi.exe
    - GET:default.jsp

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

Alerts (14)
- Cross Site Scripting (Reflected) (2)
  - GET:http://demo.testfire.net/search.jsp (query)
  - POST:http://demo.testfire.net/sendFeedback ()(cfile,comme
- SQL Injection (2)
- Absence of Anti-CSRF Tokens (3)
- Content Security Policy (CSP) Header Not Set (Systemic)
- Missing Anti-clickjacking Header (Systemic)
- Sub Resource Integrity Attribute Missing
- Cookie without SameSite Attribute (3)
- Cross-Domain JavaScript Source File Inclusion
- Server Leaks Version Information via "Server" HTTP Respons
- X-Content-Type-Options Header Missing (Systemic)
- Information Disclosure - Suspicious Comments (6)
- Modern Web Application (4)

Source: Active (40012 - Cross Site Scripting (Reflected))

Input Vector: Form Query

Description:

Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML/JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology.

Other Info:

Solution:

Ensure that you perform input validation at well-defined interfaces within the application. This will help protect the application even if a component is reused or moved elsewhere.

Reference:

https://owasp.org/www-community/attacks/xss/
https://cwe.mitre.org/data/definitions/79.html

Alerts 2 4 4 4 | Main Proxy: localhost:8080 | Current Status 0 1 0 0 0 0 0 0 0 0 0

10:24 PM 4/6/2026